

PROJETO DE ESTÁGIO

Ponto de Controlo 2

SMARTER HUB

 Estudante:
Patrick Costa

 Supervisora:
Camila Teixeira

 Orientador:
Marílio Cardoso

Conteúdo

1	Introdução e Contexto	4
1.1	Descrição da empresa	4
1.2	Contextualização da área de negócio	4
2	Necessidade e Problema a Resolver	4
2.1	Situação atual	4
2.2	Análise de causas	5
2.3	Perspetiva do utilizador - Empathy Map	5
2.4	Métricas atuais e metas futuras	6
2.5	Estimativa de valor económico (ROI)	6
2.6	Estado futuro esperado (TO-BE)	7
3	Estado da Arte	7
3.1	Abordagens atuais ao problema	7
3.2	Eixos de referência bibliográfica	7
3.3	Padrão arquitetural e auditabilidade	8
3.4	Limitações das abordagens existentes	8
3.5	Comparação com soluções de mercado (buy <i>vs</i> build)	8
3.6	Comparação de abordagens tecnológicas	9
3.7	Comparação de estratégia de testes para casos legais de RH	9
3.8	Síntese e implicações para a solução	10
3.9	Referências base consideradas	10
4	Stakeholders	10
4.1	Matriz de stakeholders	10
5	Conceção da Solução	11
5.1	Descrição da solução	11
5.2	Princípios da solução	11
5.3	Estrutura funcional	12
5.3.1	Módulos da plataforma	12
5.3.2	Modelo de autorização	12
5.4	Épicos da solução	13
5.5	Elementos de análise	13
5.5.1	Catálogo de Use Cases	13
5.5.2	User Stories	16
5.5.3	Critérios de aceitação por épico	18
5.6	Descrição técnica	21
5.6.1	Arquitetura lógica	21
5.6.2	Garantia de rasto imutável e integridade de decisão	22
5.6.3	Fluxos críticos	22

5.6.4	Modelo de dados	25
5.6.5	Práticas DevSecOps e maturidade de entrega	25
6	Objetivos	26
6.1	Objetivo geral	26
6.2	Objetivos específicos	26
6.3	Racional dos objetivos	26
6.4	Alinhamento temporal PC2 e cronograma corrigido	26
7	Gestão de Riscos	27
7.1	Riscos identificados	27
7.2	Matriz probabilidade × impacto	28
7.3	Plano de contingência para tarefas críticas	28
7.4	Matriz de risco preditiva e mitigação ativa	28
7.5	Plano de resposta	29
8	Conclusão	29

1 Introdução e Contexto

1.1 Descrição da empresa

A **Tlantic Portugal – Sistemas de Informação, S.A.** é uma empresa portuguesa de desenvolvimento de software especializada em soluções que otimizam a eficiência operacional, a gestão de pessoas e as vendas no retalho físico. Fundada em 2004 no Brasil no seio do Grupo Sonae, expandiu-se para Portugal em 2007, onde estabeleceu a sua sede no Porto. Com mais de vinte anos de experiência, tornou-se independente em 2018 e consolidou presença em Portugal e Brasil, contando atualmente com uma equipa de 51 a 200 colaboradores.

A Tlantic posiciona-se como parceira estratégica de empresas dos sectores do retalho, indústria e saúde, ajudando-as a aumentar a produtividade, reduzir custos e melhorar a experiência tanto de colaboradores como de clientes. Os seus clientes incluem grupos como Continente, Lidl, Worten e CUF.

1.2 Contextualização da área de negócio

A empresa opera no mercado de **software de gestão operacional** para ambientes físicos intensivos em mão-de-obra. As suas plataformas resolvem desafios como a previsão e planeamento de horários de equipas, o cumprimento da legislação laboral, a gestão de tarefas em loja ou armazém e a otimização do processo de vendas.

A Tlantic diferencia-se pela profunda experiência prática no retalho, pela integração entre gestão de pessoas, operações e vendas, e por uma abordagem centrada nas pessoas - oferecendo uma alternativa ágil e especializada face a soluções genéricas ou internacionais. O segmento em que atua encontra-se em forte crescimento, impulsionado pela transformação digital do retalho físico, pela pressão sobre custos laborais e pela exigência crescente de compliance.

2 Necessidade e Problema a Resolver

2.1 Situação atual

Problema central: ausência de uma plataforma única de governança operacional para processos de pessoas - incluindo gestão das informações pessoais dos colaboradores, uniformização e atualização contínua de processos, pedidos de férias, aprovações multi-nível, gestão de permissões e evidências de auditoria - conduzindo a ineficiências, erro humano, duplicação documental e incapacidade de decisão baseada em dados.

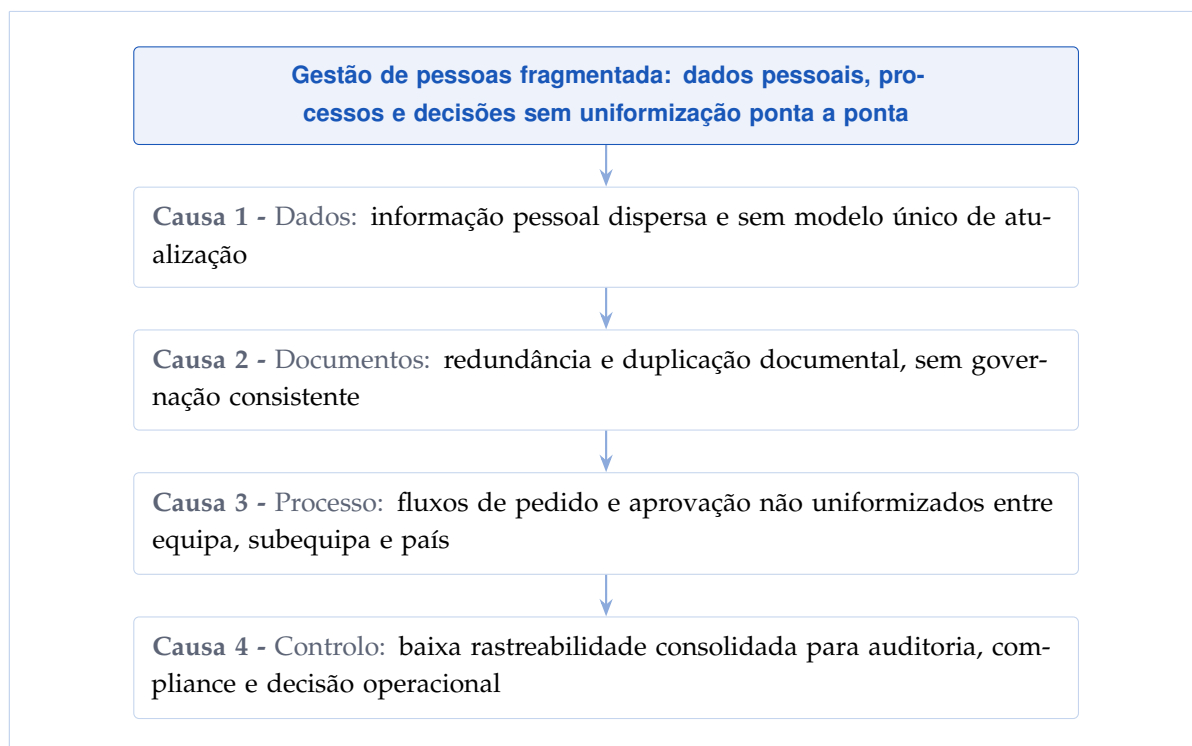
Na maioria das organizações com operações distribuídas, o problema manifesta-se de forma recorrente através de:

- informação pessoal de colaboradores dispersa por múltiplas fontes, com baixa consistência e difícil atualização;
- coexistência de documentos redundantes/duplicados sem controlo de versão funcional;

- processos fragmentados entre email, folhas de cálculo e aprovações informais;
- baixa padronização e atualização de processos entre equipas, subequipas e geografias;
- dificuldade em aplicar políticas legais distintas por país de forma consistente;
- falta de visibilidade operacional sobre capacidade e sobreposição de ausências;
- rastreabilidade insuficiente para auditoria, compliance e melhoria contínua.

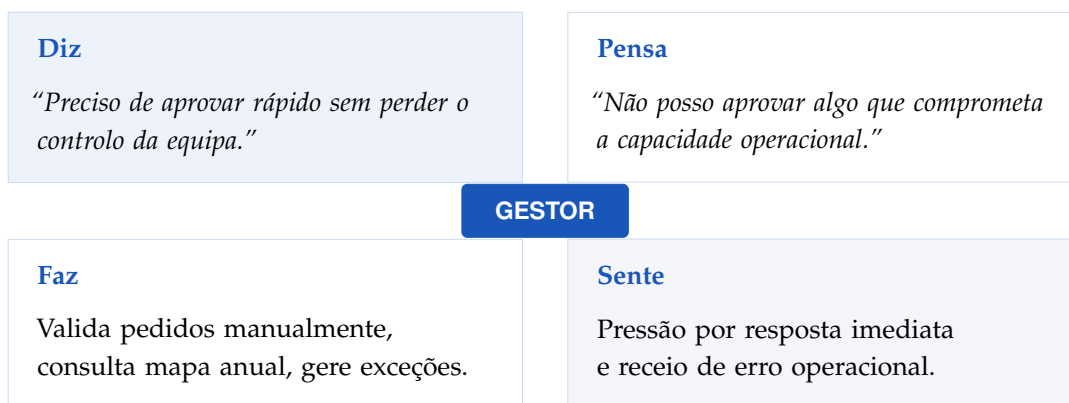
2.2 Análise de causas

O diagrama seguinte sintetiza a cadeia causal do problema, partindo do sintoma visível até às causas raiz identificadas.



2.3 Perspetiva do utilizador - Empathy Map

O perfil primário de utilização é o **gestor de equipa**, cuja experiência atual concentra os principais pontos de atrito:



2.4 Métricas atuais e metas futuras

Para garantir avaliação objetiva da solução, os KPIs seguintes ficam definidos com baseline, meta temporal e regra de cálculo explícita.

Métrica	Baseline atual	Meta futura	Método de medição
Tempo médio de aprovação ponta a ponta	72–120h	≤ 24 h (até M+2)	Mediana entre <code>createdAt</code> e decisão final
Pedidos com retrabalho	10–20%	$\leq 5\%$ (até M+2)	Taxa de re-submissão por mês
Produção do mapa anual de férias	20–40 min	< 2 min (até M+1)	Tempo médio de exportação XLSX
Registos pessoais desatualizados	18–25% dos perfis	$\leq 5\%$ (até M+3)	Perfis sem atualização > 180 dias
Documentos duplicados por colaborador	8–12%	$\leq 2\%$ (até M+3)	Auditoria mensal de anexos/documentos
Conflitos de capacidade detetados tardiamente	12–18 casos/mês	≤ 3 casos/mês (até M+3)	Alertas por sobreposição após aprovação
SLA de notificação pós-decisão	2–6h	≤ 15 min (até M+2)	<code>decisionAt</code> $\rightarrow$ <code>notificationSentAt</code>
Satisfação interna (escala 1–5)	3.0–3.5 / 5	≥ 4.2 / 5 (até M+4)	Inquérito trimestral segmentado por perfil

Os valores de baseline são referências operacionais para arranque e devem ser recalibrados após 4 semanas de telemetria. Nesta proposta, M corresponde ao mês de entrada em produção do MVP.

2.5 Estimativa de valor económico (ROI)

Para posicionar o projeto como decisão de engenharia com impacto de negócio, foi definida uma estimativa conservadora de retorno anual:

- esforço atual de gestão de férias e retrabalho administrativo: **62 h/mês** (gestores + RH);
- esforço previsto após estabilização do SMARTER HUB: **24 h/mês**;
- horas poupadas: 38 h/ms (456 h/ano);
- custo horário médio interno estimado: **€ 28/h**;
- poupança anual estimada: $456 \times 28 = \text{€ } 12\,768/\text{ano}$.

Indicador	Antes (Mensal)	Após (M+3)
Horas de gestão operacional	62 h	24 h
Custo operacional estimado	€ 1.736	€ 672
Poupança Mensal		€ 1.064
Poupança Anual		€ 12.768

Fórmula de ROI usada no PC2: $ROI(\%) = \frac{BAE - CAI}{CAI} \times 100$

Onde: BAE: Benefício Anual Estimado; CAI: Custo Anual do Investimento.

A versão final do KPI financeiro será fechada no PC3 com custo real de implementação e operação.

2.6 Estado futuro esperado (TO-BE)

Independentemente da solução tecnológica adotada, o estado futuro desejado assenta em quatro vetores:

- gestão unificada e atualizável da informação pessoal de colaboradores;
- redução de redundância documental através de fluxos únicos e auditáveis;
- processo de pedido e aprovação totalmente rastreável de ponta a ponta;
- redução consistente do tempo de resposta e do retrabalho administrativo;
- governação de acessos mais robusta, com menor risco de escalada indevida;
- maior previsibilidade de capacidade de equipas e melhor suporte à decisão operacional.

A materialização concreta destes resultados é apresentada na Secção 5.

3 Estado da Arte

3.1 Abordagens atuais ao problema

No estado da prática, o problema é habitualmente endereçado por combinações ad-hoc:

- folhas de cálculo para planeamento de férias e capacidade;
- trocas de email e mensagens para circuitos de aprovação;
- sistemas de RH generalistas com baixo nível de adaptação ao fluxo real;
- plataformas enterprise com motor de workflow, mas custo elevado de parametrização.

3.2 Eixos de referência bibliográfica

Foram considerados quatro eixos de fundamentação:

- **Workflows de aprovação:** sistemas enterprise tendem para motores de estado com transições explícitas (PENDING, APPROVED, REJECTED, CANCELLED) e trilha de decisão por ator.

- **Controlo de acesso:** a combinação de RBAC com restrições contextuais (equipa, país, nível hierárquico) aproxima-se de modelos ABAC de baixa complexidade, adequados a organizações em crescimento.
- **Sistemas de RH digitais:** boas práticas exigem histórico imutável, operações auditáveis e consistência entre a visão do colaborador, da chefia e do administrador.
- **UX operacional:** interfaces de baixo atrito para tarefas repetitivas - aprovar, exportar, consultar - melhoram a adoção e reduzem o erro humano.

3.3 Padrão arquitetural e auditabilidade

Para além da escolha de stack, a solução adota princípios de **arquitetura hexagonal** (ports & adapters) no backend para separar regras de negócio de detalhes de framework e infraestrutura. Esta decisão é diretamente motivada por requisitos de auditoria e conformidade:

- as regras críticas (aprovar/rejeitar férias, crédito de saldo, concessão/revogação de permissão) residem em serviços de domínio;
- os adapters (HTTP, Prisma, notificações) apenas executam I/O, sem decidir política de negócio;
- cada alteração sensível gera registo auditável imutável (ator, alvo, ação, motivo, timestamp) antes de confirmar conclusão do fluxo.

Este desenho reduz risco de bypass de regras por mudanças na camada web e melhora testabilidade de cenários legais de RH (limites por país, conflitos de capacidade, escopo hierárquico).

3.4 Limitações das abordagens existentes

- pouca rastreabilidade de decisão em fluxos informais;
- dificuldade em aplicar políticas distintas por país;
- fraca integração entre gestão de permissões, hierarquia e operação diária;
- baixa qualidade de reporting para decisão executiva.

3.5 Comparação com soluções de mercado (buy vs build)

Para elevar o rigor de engenharia, a análise inclui alternativas de mercado relevantes para gestão de RH e férias.

Solução	Pontos fortes	Limitações (Contexto)	Conclusão
Personio	Cobertura RH ampla (dados, ausências, workflows) e produto maduro.	Menor flexibilidade para regras específicas por subequipa e integração de permissões.	Parcial

Solução	Pontos fortes	Limitações (Contexto)	Conclusão
BambooHR	UX consolidada e adoção rápida para processos standard.	Personalização limitada de políticas PT/BR e autorização contextual profunda.	Parcial
SMARTER HUB	Ajuste total às regras reais, controlo de roadmap e integração nativa.	Maior esforço inicial de implementação e necessidade de hardening contínuo.	Escolhida

Justificação da opção interna: a decisão *build* foi selecionada porque o problema central é menos “ter um HRIS genérico” e mais “governar decisões operacionais com regras contextuais e trilha auditável adaptado ao processo real da organização”. As alternativas de mercado reduzem tempo de arranque, mas aumentam custo de adaptação e risco de desalinhamento funcional no médio prazo.

3.6 Comparação de abordagens tecnológicas

A tabela seguinte resume a análise comparativa de stack, conduzida com base em produtividade, tipagem, manutenção, maturidade de ecossistema e custo de operação.

Tecnologia	Vantagens	Limitações	Decisão
React + TS (Vite)	UI reativa e tipagem forte; alta produtividade.	Gestão de estado complexa em vistas densas.	Adotada
Node.js + Express	Ecossistema amplo; desenvolvimento veloz de APIs.	Exige esforço manual em segurança e estruturação.	Adotada
Prisma + Postgres	Modelagem clara com migrações e tipagem nativa.	Dependência do ciclo generate/migrate.	Adotada
Firebase	Integração rápida de serviços cloud secundários.	Aumenta a heterogeneidade da stack.	Parcial

3.7 Comparação de estratégia de testes para casos legais de RH

Ferramenta	Força principal	Limitação	Adequação
Vitest + Supertest	Validação rápida de edge cases (regras PT/BR e escopos).	Não valida a experiência real no browser.	Alta

Ferramenta	Força principal	Limitação	Adequação
Playwright	Cobertura E2E realista (User → API → UI); deteção de regressões.	Execução lenta; alto custo de manutenção.	Alta
Jest	Ecossistema maduro e ampla adoção no mercado.	Menor alinhamento com a stack Vite escolhida.	Média

A estratégia adotada combina **Vitest + Supertest** para exaustão de regras legais e de permissão com **Playwright** para validar os fluxos críticos de negócio ponta a ponta.

3.8 Síntese e implicações para a solução

O Estado da Arte precede a secção de conceção por razão metodológica: a proposta tecnológica adotada não é arbitrária, mas consequência da análise funcional e tecnológica aqui realizada. Assim, as decisões de arquitetura e stack são justificadas pelo contexto e não apenas descritas.

3.9 Referências base consideradas

- NIST SP 800-162 - *Guide to Attribute Based Access Control (ABAC) Definition and Considerations* (base conceptual para controlo contextual de acesso).
- NIST SP 800-53 Rev. 5 - controlos de *Audit and Accountability* e *Access Control* (rastreabilidade e governação de privilégios).
- BPM CBOK (ABPMP) - boas práticas de modelação e uniformização de processos de negócio.
- ISO 9001:2015 - princípios de padronização, melhoria contínua e controlo documental em processos organizacionais.
- ISO/IEC 27001:2022 - requisitos de gestão de segurança da informação aplicáveis a controlo de acesso e registo de eventos.

4 Stakeholders

4.1 Matriz de stakeholders

Stakeholder	Influência	Interesse	Estratégia de gestão
Direção RH	Alta	Alta	Envolvimento direto na priorização de regras de férias, permissões e compliance

Stakeholder	Influência	Interesse	Estratégia de gestão
Aprovadores / gestores	Alta	Alta	Validação contínua de fluxos de aprovação por etapa e capacidade de equipa
Direção executiva	Alta	Média	Reporting periódico de indicadores de produtividade e risco
Gestores de permissões	Média	Alta	Definição da governança de capacidades, escopo e exceções operacionais
Colaboradores	Baixa	Alta	UX clara, feedback rápido e visibilidade do estado dos pedidos
Equipa TI / Dev	Média	Alta	Hardening técnico, testes automatizados e monitorização

5 Conceção da Solução

5.1 Descrição da solução

O SMARTER HUB é uma plataforma web integrada para gestão operacional de processos de pessoas, com foco em consistência de regras, governação por permissões e rastreabilidade de decisão. O sistema implementa um modelo de autorização centrado em *permissões efetivas* - não em papéis fixos de interface. Na prática, cada ação é validada pela combinação de:

- permissão atribuída ao utilizador (e.g., `approve_vacation`, `manage_permissions`);
- restrições de escopo por equipa, país e nível hierárquico quando aplicável;
- sinalizadores de privilégio elevado (`hasAccessTotal` e `isRootAccess`);
- trilho auditável de concessão/revogação de acesso (`PermissionGrant`).

5.2 Princípios da solução

- **Autorização verificável:** cada endpoint sensível valida a permissão e o escopo efetivo do ator antes de executar.
- **Conformidade por política:** as regras PT/BR são avaliadas antes de aceitar ou fechar pedidos de férias.
- **Rastreabilidade de decisão:** aprovações, recusas e alterações de permissões ficam registadas com ator, timestamp e motivo.
- **Operação contextual:** equipa, memberships e país de trabalho influenciam a elegibilidade e a visibilidade de cada utilizador.
- **Evolução controlada:** as regras de negócio concentram-se no backend; a interface foca-se na operação diária.

5.3 Estrutura funcional

Módulos da plataforma

Módulo	Objetivo	Capacidades principais
Férias e ausências	Gerir ciclo completo de pedido	Criar pedido, validar políticas, aprovar/rejeitar por etapa, histórico e versionamento
Permissões e acesso total	Governar capacidades por utilizador	Atribuir/revogar permissão, restringir escopo, gerir acesso total, auditar GRANT/REVOKE
Dias extra da empresa	Parametrizar calendário por país	Configurar dias PT/BR para suporte às regras operacionais
Crédito de saldo	Tratar exceções de saldo anual	Creditar dias com motivo obrigatório para colaboradores elegíveis
Notificações	Fechar o ciclo de ação	Notificar eventos relevantes com marcação de leitura
Perfil e estrutura	Contextualizar decisão	Perfil, equipa, memberships e visibilidade operacional
Reporting operacional	Suportar decisão de gestão	Exportação anual XLSX com filtros de ano e equipa
Autenticação e sessão	Garantir identidade e contexto seguro	Login local/Microsoft, sessão autenticada e leitura do utilizador corrente
Administração de utilizadores/equipas	Gerir estrutura organizacional	CRUD de utilizadores e equipas, ativação, credenciais, memberships e importação em lote
Formações	Suportar desenvolvimento interno	Criar, atribuir, acompanhar e concluir formações
Ficheiros e anexos	Centralizar suporte documental	Upload de ficheiros para pedidos/processos e referência de URL de acesso

Modelo de autorização

Nível	Designação	Descrição
1	Catálogo	Capacidades explícitas: request_vacation, approve_vacation, manage_permissions, entre outras

Nível	Designação	Descrição
2	Escopo	Restrições por equipa, país e nível em permissões marcadas como restritivas
3	Acesso total	Cobertura funcional alargada com controlo explícito (hasAccessTotal)
4	Root	Privilégio máximo de governação e administração técnica (isRootAccess)

5.4 Épicos da solução

ID	Épico	Propósito no SMARTER HUB	Prioridade
E1	Ciclo de pedidos	Garantir criação, validação e decisão de pedidos com estados explícitos e histórico	Alta
E2	Governança de acesso	Controlar capacidades por permissão, escopo e acesso total com auditoria	Alta
E3	Conformidade PT/BR	Aplicar regras legais/operacionais por país antes da decisão final	Alta
E4	Exceções operacionais	Permitir crédito de saldo e decisões excecionais com controlo e rastreio	Média
E5	Operação assistida	Reduzir fricção com notificações, histórico e feedback operacional	Média
E6	Visão executiva	Suportar planeamento com exportação anual e indicadores operacionais	Média

5.5 Elementos de análise

Catálogo de Use Cases

ID	Ator	Objetivo	Fluxo principal
UC01	Utilizador	Autenticar (credenciais)	Submete credenciais, sistema valida e devolve sessão autenticada
UC02	Utilizador	Autenticar (Microsoft)	Inicia login federado e obtém sessão válida no sistema
UC03	Utilizador autenticado	Consultar sessão atual	Solicita contexto /auth/me para obter identidade e permissões efetivas

ID	Ator	Objetivo	Fluxo principal
UC04	Colaborador	Consultar perfil próprio	Acede a /profile/me para visualizar dados e contexto organizacional
UC05	Colaborador	Submeter alteração de perfil	Atualiza dados em /profile/me; sistema cria pedido rastreável de alteração
UC06	Colaborador	Consultar pedidos de perfil próprios	Lista pedidos /profile/requests/me com estado e histórico
UC07	Aprovador de perfil	Aprovar pedido de perfil	Analisa pedido pendente e confirma aprovação com registo de decisão
UC08	Aprovador de perfil	Rejeitar pedido de perfil	Analisa pedido pendente e rejeita com motivo auditável
UC09	Colaborador	Submeter pedido de férias/ausência	Define período/tipo/contexto e cria pedido para validação de regras
UC10	Sistema	Validar conformidade do pedido	Aplica políticas PT/BR, conflitos de capacidade e sobreposição antes de persistir
UC11	Colaborador	Consultar férias e saldo próprios	Consulta /vacations/me com histórico, saldo e metadados do pedido
UC12	Colaborador	Editar pedido pendente	Altera pedido em /vacations/:id mantendo trilha de alterações
UC13	Colaborador	Cancelar pedido pendente	Remove/cancela pedido em /vacations/:id conforme elegibilidade
UC14	Aprovador	Consultar pedidos para decisão	Lista /vacations/requests com pendências filtradas por escopo
UC15	Aprovador	Aprovar pedido de férias	Executa /vacations/:id/approve e atualiza estado/etapas de aprovação
UC16	Aprovador	Rejeitar pedido de férias	Executa /vacations/:id/reject com motivo e registo auditável
UC17	Gestor / RH	Consultar visão anual e calendário	Usa /vacations/overview e /vacations/calendar para planeamento
UC18	Admin operacional	Configurar dias extra da empresa	Atualiza /vacations/company-extra-days por país e período
UC19	Utilizador com acesso total	Creditar saldo de férias	Executa /vacations/assign-balance-days com motivo obrigatório
UC20	RH / Gestão	Exportar mapa anual de férias	Gera ficheiro em /vacations/export por ano/equipa/pessoa

ID	Ator	Objetivo	Fluxo principal
UC21	Gestor de permissões	Consultar catálogo de permissões	Lista /permissions e capacidades disponíveis para governação
UC22	Gestor de permissões	Consultar permissões de utilizador	Consulta /users/:id/permissions com escopos e estado
UC23	Gestor de permissões	Conceder permissão a utilizador	Cria grant em /users/:id/permissions com restrições de escopo
UC24	Gestor de permissões	Alterar escopo/estado de permissão	Atualiza grant em /users/:id/permissions/:permissionId
UC25	Gestor de permissões	Revogar permissão de utilizador	Remove grant em /users/:id/permissions/:permissionId
UC26	Gestor de permissões	Gerir acesso total	Atualiza /users/:id/access-total com auditoria de alteração
UC27	Auditor interno	Consultar trilha de grants/revokes	Acede a /audit/permission-grants para evidência de compliance
UC28	Utilizador autenticado	Gerir notificações pessoais	Lista, marca como lida (individual/todas) e elimina notificações
UC29	Gestor / RH	Consultar colaboradores e equipas	Usa /users, /users/collaborators, /teams e /teams/me
UC30	Gestor de estrutura	Atualizar memberships de equipa	Executa /manager/team-members/:id para alinhar hierarquia real
UC31	Admin	Gerir equipas (CRUD)	Usa /admin/teams para criar, editar e remover equipas
UC32	Admin	Gerir utilizadores (CRUD e estado)	Usa /admin/users, /users, /users/:id/active e operações de edição
UC33	Admin	Gerir credenciais de utilizador	Atualiza credenciais em /admin/users/:id/credentials com controlo de acesso
UC34	Admin	Importar utilizadores em lote	Submete dados em /users/import com validação e relatório de erros
UC35	Gestor de formação	Criar/editar/remover formações	Opera /trainings para manter catálogo formativo
UC36	Gestor de formação	Atribuir formação a colaboradores	Executa /trainings/assign para distribuição de ações formativas
UC37	Colaborador	Consultar e concluir formações atribuídas	Consulta /trainings/me e marca conclusão em /trainings/:id/complete

ID	Ator	Objetivo	Fluxo principal
UC38	Utilizador autenticado	Carregar ficheiros de suporte	Executa /files/upload para anexar evidências/documentos
UC39	Direção / Gestão	Consultar dashboard operacional	Usa /users/dashboard-summary para indicadores agregados

User Stories

ID	Como	Quero	Prior.
US01	Utilizador	autenticar-me com credenciais para iniciar sessão segura	Alta
US02	Utilizador	autenticar-me via Microsoft para acesso federado ao sistema	Média
US03	Utilizador autenticado	consultar a minha sessão para ver permissões e contexto atual	Média
US04	Colaborador	consultar o meu perfil para validar dados e contexto organizacional	Média
US05	Colaborador	submeter pedido de alteração de perfil com rastreabilidade do processo	Média
US06	Colaborador	consultar os meus pedidos de perfil e respetivo estado	Média
US07	Aprovador de perfil	aprovar pedido de alteração de perfil com registo auditável	Média
US08	Aprovador de perfil	rejeitar pedido de alteração de perfil com motivo explícito	Média
US09	Colaborador	submeter pedido de férias/ausência com período e contexto de equipa	Alta
US10	Sistema	validar conformidade PT/BR, sobreposição e capacidade antes de persistir o pedido	Alta
US11	Colaborador	consultar férias e saldo para acompanhar consumo e disponibilidade	Alta
US12	Colaborador	editar pedido pendente sem perder histórico de alterações	Média
US13	Colaborador	cancelar pedido pendente quando já não se aplica	Média

ID	Como	Quero	Prior.
US14	Aprovador habilitado	consultar pendências de decisão no meu escopo de aprovação	Alta
US15	Aprovador habilitado	aprovar pedido de férias com atualização de estado por etapa	Alta
US16	Aprovador habilitado	rejeitar pedido de férias com motivo e evidência de decisão	Alta
US17	Gestor / RH	consultar visão anual e calendário para planeamento de capacidade	Média
US18	Admin operacional	configurar dias extra da empresa por país e ano	Média
US19	Utilizador com acesso total	creditar saldo de férias em cenário excepcional com motivo obrigatório	Alta
US20	RH / Gestão	exportar mapa anual de férias em XLSX por ano/equipa/pessoa	Alta
US21	Gestor de permissões	consultar catálogo de permissões disponíveis para governação	Média
US22	Gestor de permissões	consultar permissões efetivas de um utilizador com escopos aplicados	Alta
US23	Gestor de permissões	conceder permissão a utilizador com restrições de escopo	Alta
US24	Gestor de permissões	atualizar escopo ou estado de uma permissão já atribuída	Alta
US25	Gestor de permissões	revogar permissão de utilizador sem ambiguidade operacional	Alta
US26	Gestor de permissões	gerir acesso total de utilizadores com trilho de auditoria	Alta
US27	Auditor interno	consultar trilho de grants/revokes para evidência de compliance	Alta
US28	Utilizador autenticado	gerir notificações pessoais (ler, ler todas, eliminar)	Média
US29	Gestor / RH	consultar utilizadores e equipas para operação diária	Média
US30	Gestor de estrutura	atualizar memberships para refletir hierarquia real da organização	Alta

ID	Como	Quero	Prior.
US31	Admin	gerir equipas (criar, editar e remover) de forma controlada	Média
US32	Admin	gerir utilizadores (criar, editar, ativar/desativar e remover)	Alta
US33	Admin	atualizar credenciais de utilizador com controlo de acesso reforçado	Média
US34	Admin	importar utilizadores em lote com validação e relatório de erros	Média
US35	Gestor de formação	criar, editar e remover formações do catálogo interno	Baixa
US36	Gestor de formação	atribuir formações a colaboradores por necessidade operacional	Baixa
US37	Colaborador	consultar e concluir formações atribuídas no meu plano de desenvolvimento	Baixa
US38	Utilizador autenticado	carregar ficheiros de suporte para anexar evidências/documentos	Média
US39	Direção / Gestão	consultar dashboard operacional com indicadores agregados	Média

Critérios de aceitação por épico

E1 — Ciclo de pedidos

- Todo pedido possui estado explícito (PENDING, APPROVED, REJECTED ou CANCELLED), timestamps de criação e decisão, e decisão rastreável com ator e motivo.
- O utilizador pode editar um pedido no estado PENDING sem perda do histórico; a entidade original é preservada.
- O utilizador pode cancelar o próprio pedido; o sistema emite notificação automática para os aprovadores da etapa corrente.
- O histórico de pedidos (/vacations/me) devolve todos os estados transitados, incluindo pedidos de anos anteriores.
- O sistema rejeita pedidos com período inválido (início > fim, sobreposição com pedido activo, período integralmente no passado sem acesso elevado).
- Cada etapa de aprovação multi-nível (VacationApproval) regista ator, decisão, motivo e timestamp independente.

E2 — Governança de acesso

- Operações de criação, actualização e revogação de permissões exigem ator com capacidade explícita e escopo compatível.
- A activação/desactivação do flag `access-total` só pode ser executada por utilizador com nível *root*.
- Todos os grants e revokes ficam registados em `PermissionGrant` com ator, alvo, permissão, ação e timestamp, de forma imutável.
- A trilha de auditoria (`/audit/permission-grants`) é consultável por gestores autorizados e não permite edição posterior.
- A cache de autorização do utilizador alvo é invalidada imediatamente após qualquer alteração de permissão.
- O endpoint `/users/:id/permissions` devolve a lista completa de permissões efetivas do utilizador a qualquer momento.

E3 — Conformidade PT/BR

- Antes de criar ou aprovar qualquer pedido, as regras de elegibilidade por país (PT/BR) são avaliadas; em caso de bloqueio, o sistema devolve motivo claro e estruturado.
- O sistema detecta sobreposição de pedidos em estado `PENDING` ou `APPROVED` para o mesmo utilizador e rejeita o novo pedido com código de erro identificável.
- A capacidade mínima da equipa é verificada antes de criar ou promover um pedido; pedidos que violem o limiar são bloqueados com indicação do critério não satisfeito.
- Dias de empresa (`VacationCompanyExtraDay`) são contabilizados no cálculo do saldo disponível e listáveis por país.
- O sistema suporta dias parciais com validação de elegibilidade por tipo de contrato e país.

E4 — Exceções operacionais

- O crédito de saldo só pode ser efectuado por utilizador com `access-total = true`; tentativas de utilizadores sem esse flag resultam em 403 com mensagem de erro clara.
- O sistema valida payload e elegibilidade do colaborador alvo antes de criar o registo `VacationBalanceCredit`.
- A atribuição de dias extraordinários (`/vacations/assign-balance-days`) gera registo auditável com motivo, autoria e timestamp.
- Cada operação de crédito ou débito gera notificação automática ao colaborador afectado.
- Dias de empresa podem ser criados, listados e filtrados por país e período; operações de escrita exigem acesso de gestor.

E5 — Operação assistida

- As notificações são entregues em tempo real e persistidas na base de dados com estado de leitura por utilizador.

- O utilizador pode marcar notificações como lidas individualmente (/notifications/:id/read) ou em lote (/notifications/read-all).
- O histórico de notificações (/notifications/me) devolve todas as notificações do utilizador, incluindo as já lidas, com suporte a paginação.
- O pedido de alteração de perfil (/profile/requests) percorre um fluxo de aprovação com ator, decisão e motivo registados; o histórico é consultável em /profile/requests/history.
- A limpeza de notificações expiradas (/notifications/cleanup) é restrita a utilizadores com nível root e devolve contagem de registos eliminados.

E6 — Visão executiva

- O dashboard (/users/dashboard-summary) devolve métricas consolidadas por equipa e país, calculadas em tempo real.
- O calendário de férias (/vacations/calendar) devolve eventos agrupados por equipa e período; a granularidade é suficiente para deteção visual de conflitos.
- A exportação anual (/vacations/export) gera workbook XLSX via ExcelJS com todos os colaboradores do escopo autorizado, pronto para análise de capacidade.
- O endpoint /vacations/overview devolve sumário de pedidos por estado, filtrável por equipa e período, para apoio à decisão de gestão.
- O utilizador com acesso executivo pode filtrar todas as vistas por equipa, país e intervalo temporal sem acesso a dados fora do seu escopo.

E7 — Autenticação e identidade

- O login por credenciais (/auth/login) valida email e password, devolve token JWT com claims de identidade e expiração definida.
- O login por Microsoft OAuth (/auth/microsoft) devolve token válido e cria ou actualiza o utilizador na base de dados de forma idempotente.
- O endpoint /auth/me devolve os dados do utilizador autenticado a partir do token, sem novos acessos à base de dados desnecessários.
- Tokens inválidos ou expirados são rejeitados com HTTP 401 sem vazamento de detalhes internos na resposta.
- O endpoint /auth/account devolve dados de conta incluindo permissões efectivas e flags de acesso.

E8 — Gestão administrativa

- O administrador pode criar, listar, actualizar e desactivar utilizadores (/admin/users, /users).
- A gestão de equipas suporta ciclo CRUD completo (/admin/teams), incluindo hierarquia pai/subequipa.
- A importação de utilizadores (/users/import) valida o ficheiro antes de aplicar alterações;

erros de validação são devolvidos linha a linha.

- O gestor pode adicionar e remover memberships de utilizadores em equipas (/admin/users/:id/memberships).
- O endpoint /admin/users/:id/credentials permite redefinir credenciais de acesso com registo auditável do ator.
- A desactivação de um utilizador (/users/:id/active) é reversível e não elimina dados históricos.

E9 — Formação e ficheiros

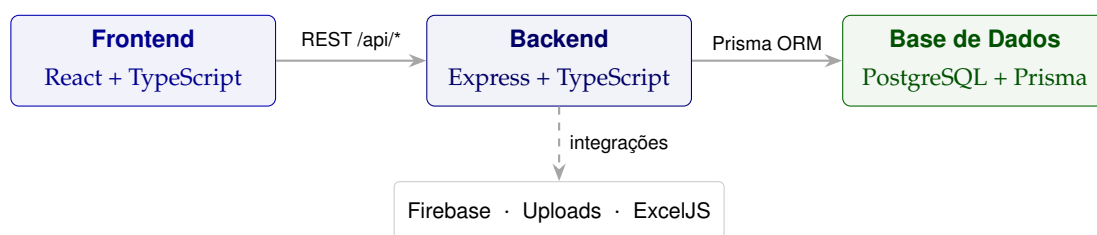
- As formações podem ser criadas, atribuídas a colaboradores e marcadas como concluídas (/trainings/*).
- O utilizador só pode consultar formações que lhe foram atribuídas ou que ele próprio criou (/trainings/me, /trainings/assigned).
- A conclusão de uma formação (/trainings/:id/complete) gera registo auditável com data, utilizador e estado anterior.
- O upload de ficheiros (/files/upload) valida tipo MIME, tamanho máximo e associação ao utilizador autenticado; ficheiros inválidos são rejeitados antes de persistência.
- Ficheiros enviados ficam associados ao utilizador de origem e são acessíveis apenas no contexto autorizado.

5.6 Descrição técnica

Arquitetura lógica

A solução organiza-se em três camadas com separação clara de responsabilidades:

- **Frontend** (React + TypeScript + Vite): páginas por domínio funcional, componentes reutilizáveis e deduplicação de pedidos em desenvolvimento.
- **Backend** (Express + TypeScript): rotas por contexto (vacations, permissions, profile, notifications, users), validação por Zod e motor de autorização por permissões/escopo.
- **Dados** (PostgreSQL + Prisma): modelo relacional com entidades de pedido, aprovação, governação de acesso, perfil e estrutura organizacional.



Garantia de rasto imutável e integridade de decisão

Em operações críticas, a arquitetura aplica o princípio “**sem rasto, sem commit**”: alterações de estado só são consideradas concluídas quando os registos de auditoria associados são persistidos no mesmo fluxo transaccional da decisão de negócio.

- aprovações e recusas mantêm ator, decisão, motivo e timestamp em entidades de trilha de decisão;
- grants/revokes de permissões ficam registados em `PermissionGrant`;
- ações de privilégio elevado (acesso total/root) exigem validação explícita do ator e ficam auditadas.

Este mecanismo reduz risco de alterações silenciosas e sustenta evidência objetiva para compliance e auditoria interna.

Fluxos críticos

Fluxo 1 — Pedido e aprovação de férias

1. O utilizador cria um pedido com período, tipo, contexto de equipa e indicador de dia parcial.
2. O backend valida formato, política por país (PT/BR), sobreposições e capacidade disponível.
3. O sistema cria a entidade `Vacation` e as etapas `VacationApproval` por aprovadores configurados.
4. Cada decisor aprova ou rejeita a sua etapa com motivo; o pedido transita para estado final.
5. O colaborador é notificado do resultado; o estado passa a `APPROVED` ou `REJECTED`.

Fluxo 2 — Edição e cancelamento de pedido de férias

1. O utilizador selecciona um pedido em estado `PENDING` e edita o período ou tipo.
2. O backend re-valida as regras de negócio com os novos dados; o histórico original é preservado.
3. Em alternativa, o utilizador cancela o pedido; o sistema transita para `CANCELLED` e notifica os aprovadores pendentes.
4. O saldo disponível é recalculado e reflectido na vista do utilizador.

Fluxo 3 — Crédito de saldo de férias

1. O utilizador com `access-total` inicia um crédito para um colaborador alvo.
2. O backend valida payload, elegibilidade do alvo e escopo do ator.
3. O sistema cria o registo `VacationBalanceCredit` com motivo e autoria.
4. O colaborador recebe notificação do crédito efectuado; o saldo é actualizado em tempo real.

Fluxo 4 — Exportação do mapa de férias

1. O utilizador com acesso total/root selecciona ano e equipa.
2. O endpoint gera um workbook XLSX via ExcelJS com os dados relevantes para gestão.
3. O ficheiro é descarregado para análise e partilha operacional.

Fluxo 5 — Governança de permissões

1. O gestor de permissões selecciona o utilizador alvo e a capacidade a alterar.
2. Define escopo (equipa, país, nível), estado da permissão e motivo da alteração.
3. O sistema valida a autorização do ator, aplica a mudança e invalida a cache de autorização do alvo.
4. Regista o evento de auditoria (GRANT/REVOKE) em `PermissionGrant` com ator, alvo e timestamp.
5. O perfil alvo passa a operar com o novo conjunto de capacidades na próxima operação autenticada.

Fluxo 6 — Autenticação por credenciais e Microsoft OAuth

1. O utilizador submete email e password em `/auth/login`; o backend valida as credenciais e devolve JWT.
2. Em alternativa, o utilizador inicia fluxo OAuth em `/auth/microsoft`; o backend troca o código por token Microsoft e cria/actualiza o utilizador de forma idempotente.
3. O token JWT é incluído em todas as chamadas subsequentes via header `Authorization: Bearer`.
4. Token inválido ou expirado resulta em HTTP 401 sem exposição de detalhes internos.
5. O endpoint `/auth/me` valida o token e devolve identidade, flags e permissões efectivas.

Fluxo 7 — Pedido de alteração de perfil e aprovação

1. O colaborador submete um pedido de alteração de dados em `/profile/requests` com os campos a modificar e justificação.
2. O sistema cria a entidade `ProfileChangeRequest` em estado `PENDING` e notifica o gestor responsável.
3. O gestor aprova ou rejeita o pedido em `/profile/requests/:id/approve` ou `/profile/requests/:id/reject` com motivo.
4. Em caso de aprovação, os dados do perfil (`/profile/me`) são actualizados atómicamente.
5. O colaborador é notificado do resultado; o histórico fica disponível em `/profile/requests/history`.

Fluxo 8 — Ciclo de vida de notificações

1. O sistema gera uma notificação em resposta a eventos de domínio (decisão de pedido, crédito de saldo, alteração de permissão, etc.).
2. O utilizador consulta as notificações não lidas em `/notifications/me`.
3. O utilizador marca uma notificação como lida (`/notifications/:id/read`) ou todas em

lote (/notifications/read-all).

4. O utilizador pode eliminar notificações individualmente ou em massa (/notifications/:id DELETE, /notifications DELETE).
5. Um utilizador root executa a limpeza periódica de notificações expiradas (/notifications/cleanup), obtendo contagem de registos eliminados.

Fluxo 9 — Criação e gestão de utilizadores (admin)

1. O administrador cria um utilizador em /users (POST) com nome, email, país e perfil inicial.
2. Em alternativa, importa múltiplos utilizadores via /users/import com ficheiro CSV/J-SON; erros de validação são devolvidos linha a linha.
3. O administrador atribui o utilizador a equipas em /admin/users/:id/memberships.
4. Quando necessário, o administrador desactiva o utilizador em /users/:id/active (reversível, sem perda de histórico).
5. A redefinição de credenciais é efectuada em /admin/users/:id/credentials com registo auditável do ator.

Fluxo 10 — Atribuição e conclusão de formação

1. O gestor cria uma formação em /trainings (POST) com título, descrição e prazo.
2. O gestor atribui a formação a colaboradores em /trainings/assign; cada atribuição gera notificação ao destinatário.
3. O colaborador consulta as suas formações pendentes em /trainings/me e /trainings/assigned.
4. O colaborador marca a formação como concluída em /trainings/:id/complete; o registo inclui data e utilizador.
5. O gestor pode actualizar ou remover formações via /trainings/:id (PUT/DELETE) enquanto não há conclusões registadas.

Fluxo 11 — Consulta de visão executiva e calendário

1. O gestor acede ao dashboard em /users/dashboard-summary; o sistema devolve métricas de férias, saldo e equipa calculadas em tempo real.
2. O gestor consulta o calendário de férias em /vacations/calendar com filtros de equipa e período; conflitos são imediatamente visíveis.
3. O gestor acede ao overview de pedidos em /vacations/overview para análise de carga por estado.
4. O gestor exporta o mapa anual em /vacations/export e obtém workbook XLSX para análise offline.
5. Todos os dados de visão executiva respeitam o escopo do ator; dados fora do escopo autorizado nunca são incluídos na resposta.

Fluxo 12 — Upload de ficheiro

1. O utilizador selecciona um ficheiro e submete para /files/upload via multipart/form-data.
2. O backend valida tipo MIME, tamanho máximo e associação ao utilizador autenticado antes de persistir.
3. O ficheiro é armazenado com identificador único; a referência é devolvida na resposta para uso posterior.
4. Ficheiros inválidos (tipo não permitido, tamanho excedido) são rejeitados com código de erro descritivo antes de qualquer escrita em disco.

Modelo de dados

Entidades principais implementadas no schema:

- User - identidade, flags de acesso total e root, relação com perfil e memberships
- Team e TeamMembership - estrutura organizacional e papéis por equipa
- Vacation e VacationApproval - pedido e trilha de aprovação multi-nível
- Permission, UserPermission e PermissionGrant - governança de acesso
- VacationCompanyExtraDay - dias automáticos da empresa por país
- Notification, Training, ProfileChangeRequest - módulos de suporte

Relacionamentos principais:

- Team 1..N TeamMembership ; User 1..N TeamMembership
- User 1..N Vacation ; Vacation 1..N VacationApproval
- User 1..N UserPermission ; Permission 1..N UserPermission
- User 1..1 Profile
- Team (pai) 1..N Team (subequipa)

Práticas DevSecOps e maturidade de entrega

Segurança (RBAC + restrições contextuais):

- o acesso não é concedido por perfil visual da UI, mas por permissão efetiva validada em backend;
- operações sensíveis verificam escopo por equipa, país e nível hierárquico;
- princípio de menor privilégio: utilizadores só executam ações explicitamente concedidas.

Qualidade e entrega contínua (CI/CD):

- pipeline automatizada com validação de lint, testes unitários/integração e E2E crítico;
- política de *quality gate*: sem testes verdes, não há promoção para ambiente de release;
- evidências de execução (logs e relatórios) versionadas como artefato técnico de auditoria.

Exemplo de controlo de acesso esperado: um utilizador sem `approve_vacation` e sem escopo compatível não consegue consultar nem alterar saldos/decisões de outro colaborador, mesmo que tente invocar o endpoint diretamente.

6 Objetivos

6.1 Objetivo geral

Conceber e operacionalizar uma plataforma única para gestão de processos de pessoas - férias, ausências, perfil, formações, notificações e permissões -, garantindo governança por permissões e escopo, rastreabilidade de decisões e melhoria mensurável de eficiência operacional.

6.2 Objetivos específicos

1. Implementar cadeia de aprovação de férias por hierarquia real (equipa e subequipa), incluindo validação multi-nível.
2. Aplicar políticas de férias por país (PT/BR), com regras legais e operacionais distintas.
3. Centralizar controlo de permissões granulares com restrições de escopo por equipa, país e nível.
4. Garantir exportação executiva do mapa de férias em XLSX, com filtro por ano e equipa.
5. Permitir crédito de saldo de férias por perfis com acesso total em cenários excecionais e auditáveis.
6. Reforçar a auditabilidade de ações sensíveis: grants/revokes, aprovações e exceções operacionais.

6.3 Racional dos objetivos

Dimensão	Como os objetivos endereçam o problema
Tempo e previsibilidade	Fluxo de aprovação automatizado por etapas habilitadas, com estados explícitos e notificações imediatas
Conformidade	Regras PT/BR e controlo de escopo eliminam decisões fora de norma e reduzem risco legal
Governança	Permissões granulares, restrições de escopo e acesso total equilibram autonomia operacional e controlo
Decisão baseada em dados	Mapa anual exportável e visibilidade agregada por equipa suportam planeamento de capacidade

6.4 Alinhamento temporal PC2 e cronograma corrigido

Para evitar incoerência entre relatório e planeamento, os entregáveis do marco **PC2 (até 01/05)** ficam explicitamente delimitados a artefactos de baseline e validação inicial:

- baseline funcional de endpoints por domínio (catálogo e contratos de entrada/saída);
- evidências de testes iniciais (unitários/integrados) nas rotas críticas;
- backlog priorizado e plano de execução para iterações de implementação de maio/junho;
- critérios de aceite e matriz de riscos já versionados.

As iterações de desenvolvimento *core*, hardening final e fecho do MVP mantêm-se no período subsequente do cronograma, sem contradizer o conteúdo de anexos do PC2.

7 Gestão de Riscos

7.1 Riscos identificados

ID	Risco	Prob.	Impacto	Mitigação
R1	Alteração de regras sem atualização de documentação	Média	Alta	Governance: mudança de código implica atualizar documento de regras
R2	Regressão por StrictMode/double fetch no frontend	Média	Média	Cache com deduplicação in-flight e testes de regressão
R3	Falha do ciclo Prisma após mudança de schema	Média	Média	Pipeline obrigatório: prisma generate antes de build
R4	Erro de timezone no calendário (desvio de um dia)	Baixa	Alta	Uso consistente de YYYY-MM-DD sem toISOString
R5	Escalada indevida de privilégios	Baixa	Alta	Auditoria de grants/revokes e validação de ator autorizado
R6	Dependência de API externa de feriados (Nager.Date)	Média	Média	Cache local com TTL e fallback para operação degradada
R7	Dificuldade de adoção por perfis não técnicos	Média	Média	UX orientada a tarefa, labels claras e feedback imediato
R8	Divergência entre hierarquia real e memberships	Média	Alta	Rotinas de validação e revisão periódica por admin

ID	Risco	Prob.	Impacto	Mitigação
R9	Atraso de validação por indisponibilidade de stakeholders-chave	Média	Alta	Janela de validação alternativa, aprovador suplente e <i>time-box</i> de decisão
R10	Janela de hardening final subdimensionada para bugs críticos	Média	Alta	Reforço da janela para 1 semana, <i>buffer</i> técnico e critério <i>go/no-go</i>

7.2 Matriz probabilidade × impacto

Probabilidade	Alta			
	Média		R2, R3, R6, R7	R1, R8, R9, R10
	Baixa			R4, R5
		Baixo	Médio	Alto
		Impacto		

7.3 Plano de contingência para tarefas críticas

Bloco	Condição de ativação	Ação de contingência	Critério de recuperação
Tarefas 16–20	Atraso > 2 dias úteis nas validações com stakeholders.	Escalar para aprovador suplente e congelar escopo não-crítico.	Replaneamento aprovado e atraso residual ≤ 1 dia.
Hardening	Taxa de falhas críticas > 0 no <i>smoke test</i> .	Ativar <i>buffer</i> de 3 dias; corrigir apenas bloqueadores.	Zero falhas bloqueadoras e sucesso em testes E2E.
API Externa	Indisponibilidade da API > 4 horas em período útil.	Modo degradado com cache local e aviso ao utilizador.	API restabelecida e cache sincronizado.

7.4 Matriz de risco preditiva e mitigação ativa

Risco	Indicador	Mitigação ativa	Plano B técnico
R6 (API)	SLA < 99% na semana.	Mocking de API para desbloquear o desenvolvimento em paralelo.	Fallback para cache local versionada por ano/país.
R9 (Stake.)	Reunião adiada ≥ 2 vezes.	Pré-validação assíncrona e time-box de decisão rigoroso.	Escalada para suplente e congelamento de escopo.
R10 (Hard.)	Falhas bloqueadoras no smoke test.	Janela semanal dedicada a dívida técnica e bugs críticos.	Corte de funções não-essenciais e uso de buffer.
Integração	Taxa de erro > 5% em homologação.	Testes de contrato rigorosos e ambientes de staging.	Import/Export CSV com reconciliação diária auditada.

7.5 Plano de resposta

- **Prevenir:** checklist de release com foco em permissões, fluxos de férias e auditoria.
- **Detetar:** testes unitários/integração (Vitest + Supertest) e E2E (Playwright) por rota crítica.
- **Responder:** rollback funcional por flag ou ajuste de permissão e correção incremental.
- **Aprender:** registo estruturado de incidentes no repositório para prevenir reincidências.

8 Conclusão

O problema analisado exige uma resposta estrutural: substituir processos dispersos por um modelo integrado, governado e mensurável. A proposta consolidada no SMARTER HUB assenta em quatro pilares:

- **Regras de negócio explícitas** - reduzindo ambiguidade operacional e retrabalho administrativo;
- **Cadeia de decisão auditável** - garantindo compliance e rastreabilidade ponta a ponta;
- **Gestão de permissões por escopo** - equilibrando autonomia operacional e controlo hierárquico;
- **Visão executiva por indicadores** - suportando decisão estratégica baseada em dados.

No estado futuro esperado, a organização passa a operar com maior previsibilidade, menor retrabalho e melhor capacidade de decisão, mantendo conformidade legal e escalabilidade funcional para responder ao crescimento organizacional.